

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Caso de estudio Política de Gobierno de Seguridad

Informe de práctica

Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC



1.1 Propósito

Establecer las directrices y medidas de seguridad necesarias para proteger la confidencialidad, integridad, disponibilidad y no repudio de la información gestionada por V&L Consultores Legales, garantizando la protección de los activos físicos y digitales, así como el cumplimiento de la Ley 172-13 sobre Protección de Datos Personales.

1.2 Alcance

Esta política aplica a todos los empleados, contratistas, pasantes y terceros que tengan acceso a los sistemas, instalaciones o información de la firma. Su cumplimiento es obligatorio independientemente del cargo o función desempeñada.

1.3 Ámbito de Aplicación

Aplica a todos los activos de información de la organización, incluyendo documentos físicos y digitales, equipos informáticos, servidores, redes, dispositivos móviles, servicios en la nube y cualquier otro recurso tecnológico utilizado por la empresa.

1.4 Roles y Responsabilidades

La gerencia será responsable de aprobar y respaldar la política. El personal de TI administrará e implementará los controles de seguridad. Todos los empleados deberán cumplir las políticas establecidas, reportar incidentes y proteger la información a la que tengan acceso.

1.5 Gobernanza y Revisión

La política será supervisada por la gerencia junto con el responsable de TI. Se revisará al menos una vez al año o cuando ocurran cambios significativos en la infraestructura, procesos de negocio, requisitos legales o incidentes de seguridad relevantes.

2.1 Política de Clasificación de la Información

Propósito: Clasificar la información según su nivel de sensibilidad para garantizar su adecuada protección.

Alcance: Toda la información física y digital generada, almacenada o procesada por la organización.

Normas o Directrices: Clasificar la información como Pública, Interna, Confidencial y Restringida. El acceso deberá otorgarse según el principio de mínimo privilegio.

Responsable de Cumplimiento: Gerencia y responsable de TI.

Frecuencia de Revisión: Anualmente.

2.2 Política de Control de Acceso

Propósito: Garantizar que únicamente usuarios autorizados accedan a los recursos de información.

Alcance: Todos los usuarios, sistemas, aplicaciones y recursos tecnológicos de la empresa.

Normas o Directrices: Cada usuario tendrá credenciales únicas. Se implementarán contraseñas robustas, autenticación multifactor cuando sea posible y revisión periódica de privilegios.

Responsable de Cumplimiento: Responsable de TI.

Frecuencia de Revisión: Cada seis meses.

2.3 Política de Respaldo y Recuperación

Propósito: Asegurar la disponibilidad y recuperación de la información ante incidentes o desastres.

Alcance: Todos los sistemas, bases de datos y documentos críticos de la firma.

Normas o Directrices: Realizar copias de seguridad automáticas periódicas, almacenar respaldos en ubicaciones seguras y probar el proceso de recuperación regularmente.

Responsable de Cumplimiento: Responsable de TI.

Frecuencia de Revisión: Trimestralmente.

2.4 Política de Dispositivos Personales (BYOD)

Propósito: Regular el uso de dispositivos personales para minimizar riesgos de seguridad.

Alcance: Todo empleado que utilice dispositivos personales para acceder a información corporativa.

Normas o Directrices: Los dispositivos deberán contar con antivirus actualizado, bloqueo por contraseña y no podrán almacenar información sensible sin autorización.

Responsable de Cumplimiento: Responsable de TI y usuarios.

Frecuencia de Revisión: Anualmente.

2.5 Política de Respuesta a Incidentes

Propósito: Establecer procedimientos para detectar, reportar y responder a incidentes de seguridad.

Alcance: Todos los incidentes que afecten la confidencialidad, integridad o disponibilidad de la información.

Normas o Directrices: Todo incidente deberá ser reportado inmediatamente al responsable de TI, documentado y gestionado siguiendo un procedimiento formal.

Responsable de Cumplimiento: Responsable de TI y Gerencia.

Frecuencia de Revisión: Anualmente o después de incidentes relevantes.

2.6 Política de Uso Aceptable de Recursos TI

Propósito: Definir el uso adecuado de los recursos tecnológicos de la organización.

Alcance: Todos los empleados y terceros autorizados.

Normas o Directrices: Los recursos tecnológicos deberán utilizarse exclusivamente para fines laborales autorizados. Se prohíbe la instalación de software no autorizado y el uso indebido de Internet.

Responsable de Cumplimiento: Todos los usuarios y responsable de TI.

Frecuencia de Revisión: Anualmente.

2.7 Política de Seguridad para Terceros

Propósito: Asegurar que terceros mantengan niveles adecuados de seguridad sobre la información.

Alcance: Proveedores, consultores y socios comerciales con acceso a información o sistemas corporativos.

Normas o Directrices: Todo tercero deberá firmar acuerdos de confidencialidad y cumplir los requisitos de seguridad establecidos por la organización.

Responsable de Cumplimiento: Gerencia y responsable de TI.

Frecuencia de Revisión: Anualmente.

Conclusion

En mi opinión, la implementación de una Política de Gobierno de Seguridad de la Información es fundamental para proteger los activos de una organización. Durante el desarrollo de esta actividad comprendí la importancia de establecer controles y responsabilidades claras para garantizar la confidencialidad, integridad, disponibilidad y el no repudio de la información. Para elaborar esta propuesta me guíé por los conceptos aprendidos en clase y complementé mis ideas con herramientas de apoyo, lo que me permitió obtener una visión más amplia sobre la gestión de la seguridad de la información en un entorno real.